

PENETRATION TESTING REPORT

Project Details

Client: Mediroza General Hospital

Project: Networkwalks Penetration Testing Project – Batch B083 | Week 4

Tutor: Waqas Karim CCIE

Target: <https://medirozahospital.com>

Date: October 2026

Prepared By:

Name: _Ibrahim Usman Maiwake____

Role: Penetration Testing Intern

01. Executive Summary

This report documents a five-day black-box penetration test conducted against the Mediroza General Hospital web infrastructure. The assessment followed the Networkwalks Week 4 objectives: identify an initial access path, retrieve the three confidential patient PDF laboratory reports, recover their protected contents, and investigate the retrieved material for further critical data exposure.

The assessment identified weaknesses across authentication, patient-document protection, metadata handling, and server configuration. User enumeration and authentication weaknesses enabled access to a restricted patient area. The three retrieved PDF reports were protected with weak passwords and could be decrypted. Metadata in one report exposed an internal operational clue that led to an old server directory, where directory indexing exposed a downloadable SQL database backup containing staff salary and shareholder information.

02. Scope and Methodology

Scope:

- Target: <https://medirozahospital.com>
- Testing Type: Full black-box penetration test.
- Rules of Engagement: Testing was strictly limited to the target domain. Social engineering and Denial of Service (DoS) attacks were out of scope.

Methodology & Tools:

The assessment followed a structured penetration-testing workflow aligned with the Networkwalks milestones: reconnaissance and enumeration, authentication analysis, exploitation, document password recovery, forensic metadata analysis, and investigation of the resulting server-side lead.

- Reconnaissance & Enumeration: nmap, nslookup, and Burp Suite.
- Brute-Force & Authentication Attacks: THC Hydra coupled with SecLists and RockYou wordlists.
- Cryptography & Hash Cracking: Online HashCrack, Networkwalks PasswordCracker, and qpdf.
- Forensics & Data Analysis: exiftool.

03. Findings and Proof of Exploitation

Finding 1: User Enumeration and SQL Injection (Authentication Weakness)

The Patient Portal login interface returned different error messages depending on whether the supplied username existed. Invalid usernames returned "Username not found", while valid usernames with incorrect passwords returned "Incorrect password". This difference enabled username enumeration.

- Using hydra with a SecLists username wordlist, the user "admin" was successfully enumerated.

```
(kali㉿kali)-[~]
$ hydra -L /usr/share/seclists/Username/top-username-shortlist.txt -p test123 medirozahospital.com -s 443 https
-post-form "/patient/login.php:username=^USER^&password=^PASS^:F=Username not found"
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-01 12:48:56
[DATA] max 16 tasks per 1 server, overall 16 tasks, 17 login tries (l:17/p:1), ~2 tries per task
[DATA] attacking http-post-forms://medirozahospital.com:443/patient/login.php:username=^USER^&password=^PASS^:F=Username not found
[443][http-post-form] host: medirozahospital.com login: admin password: test123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-01 12:49:07

(kali㉿kali)-[~]
$
```

- Further manipulation of the login form revealed a SQL syntax error (mysqli_query() warning), confirming the presence of a SQL Injection vulnerability.

Patient Portal

Sign in to view your lab reports and results.

Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '#' at line 1

Username

Password

☐ Show password

Sign in

- A dictionary attack using Hydra and the rockyou.txt wordlist successfully recovered the password for the enumerated admin account in the controlled assessment environment.

Finding 2: Unauthorized Access to Patient Health Information (PHI)

Bypassing the authentication portal granted access to the internal system, which listed password-protected PDF pathology reports for three patients: S. Dlamini, P. Reddy, and E. Thompson.

Emergency: +27 11 555 0100 | Open 24/7

Log out

+

Mediroza

Home | Log out

My lab reports

Your reports are password protected. Use the password sent to you by the laboratory to open each file.

Pathology Report - S. Dlamini
Lab Ref LR-2024-1187 | 2024-11-04 | PDF (encrypted)

Download

Pathology Report - P. Reddy
Lab Ref LR-2024-1192 | 2024-11-05 | PDF (encrypted)

Download

Pathology Report - E. Thompson
Lab Ref LR-2024-1205 | 2024-11-06 | PDF (encrypted)

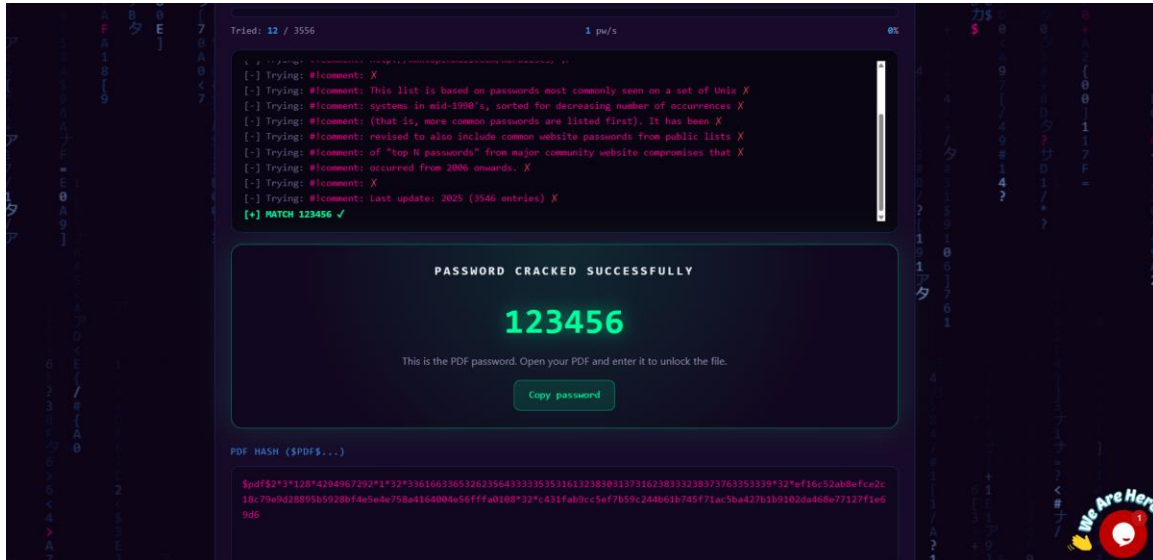
Download

© 2026 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS

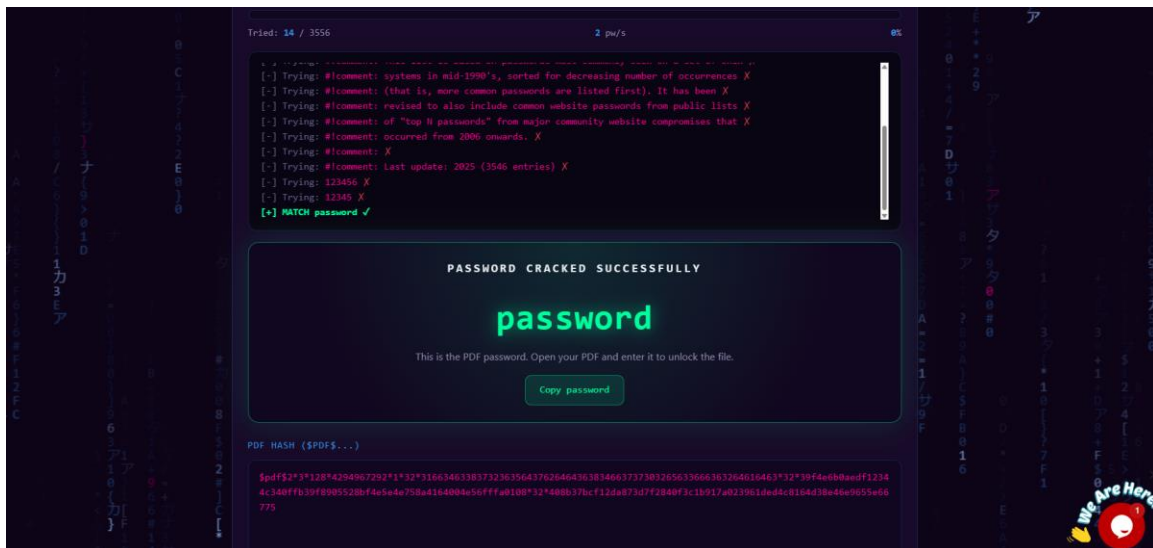
Finding 3: Weak PDF Encryption

The three retrieved PDF reports were protected with weak passwords. Password recovery was performed using the designated hash-cracking tools, after which the files were fully decrypted with qpdf.

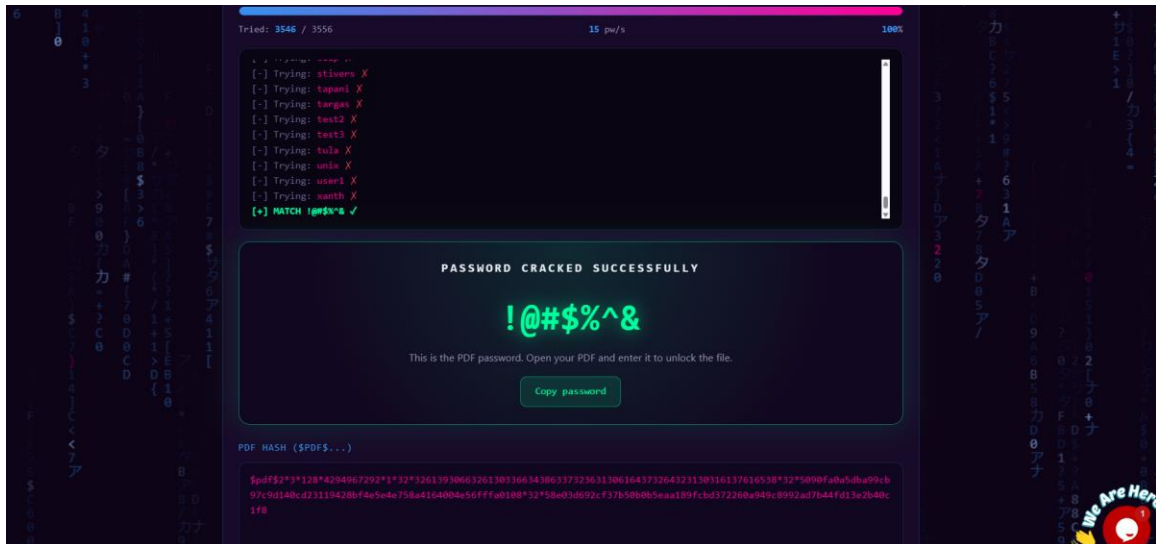
- Report 1 (S. Dlamini): Cracked using password "123456". The decrypted report revealed a high White Cell Count.



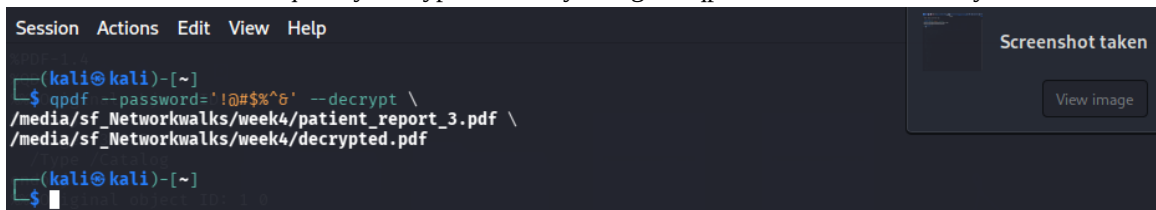
- Report 2 (P. Reddy): Cracked using password "password". The decrypted report revealed high Total Cholesterol and LDL levels.



- Report 3 (E. Thompson): Cracked using password "!@#\$%^&". The decrypted report revealed low Haemoglobin and Vitamin D levels.

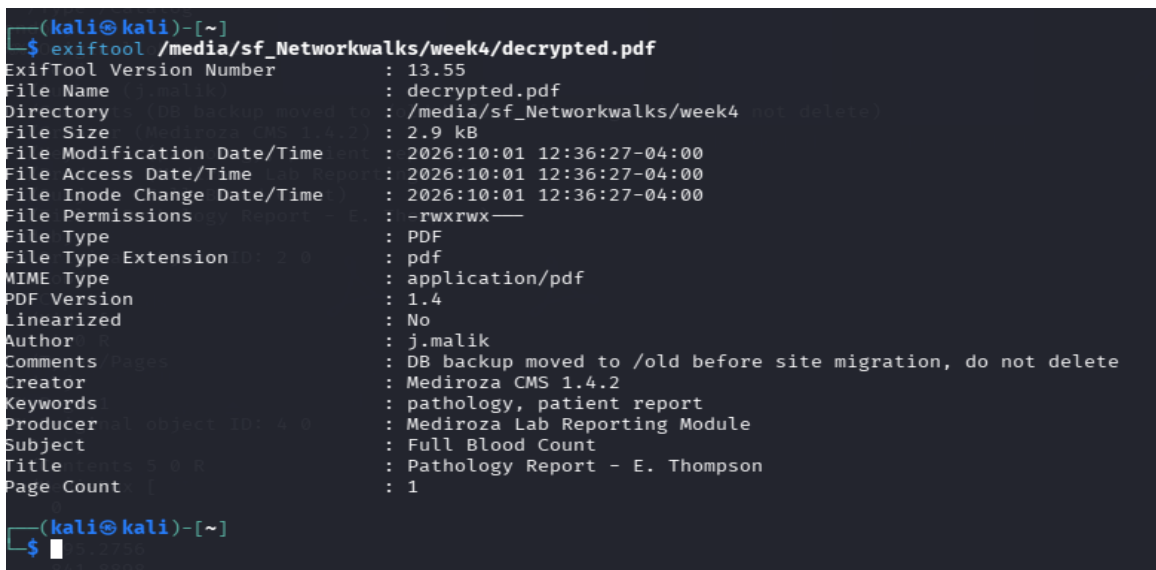


- The files were subsequently decrypted entirely using the qpdf command-line utility.



Finding 4: Information Disclosure via File Metadata

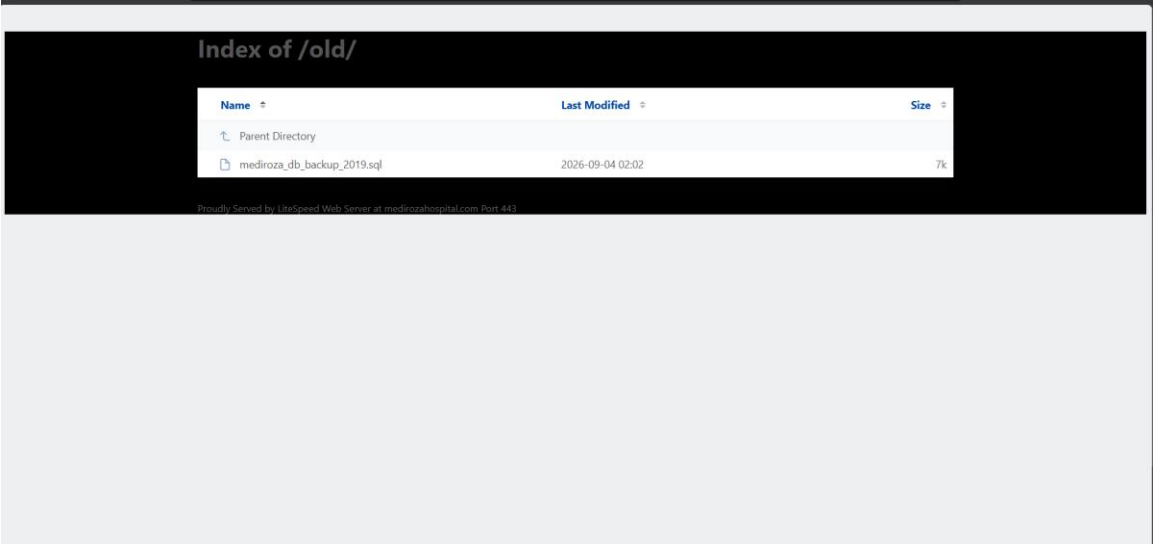
Forensic analysis of the decrypted E. Thompson PDF using exiftool exposed the creator as "j.malik" and revealed a developer comment indicating that a database backup had been moved to the /old directory before a site migration. This metadata disclosed an internal operational detail that was useful for further investigation.



Finding 5: Directory Indexing and Critical Data Exposure

Following the metadata clue, the /old/ directory was accessed and directory indexing was found to be enabled on the server.

- This directory contained a downloadable SQL database backup file named mediroza_db_backup_2019.sql (size: 7k).



- Analysis of the exposed database backup yielded hospital staff salary information and confidential shareholder details.

04. Risk Rating

Vulnerability	Severity	Justification
Exposed Database Backup	Critical	Complete compromise of corporate confidentiality. Exposed staff salaries and shareholder details, leading to massive financial and reputational damage.
SQL Injection (SQLi)	Critical	Allows attackers to bypass authentication, manipulate the backend database, and extract arbitrary data.
Weak PDF Passwords	High	Fails to protect sensitive Protected Health Information (PHI). Exploitation leads to direct HIPAA/regulatory compliance violations.
Username Enumeration	Medium	Verbose errors allow attackers to build a list of valid targets for targeted brute-force or credential stuffing attacks.
Directory Indexing	Medium	Allows attackers to browse server directories, leading to the discovery of sensitive files (like backups) that are not linked

		publicly.
Metadata Information Leakage	Low	Leaving developer comments in production files gives attackers unnecessary clues about backend infrastructure and administrative actions.

05. Recommendations and Remediation

1. Remediate SQL Injection & Authentication Bypass: Implement parameterized queries (prepared statements) for all database interactions. Validate input server-side and use secure, maintained authentication components.
2. Prevent Username Enumeration & Brute Force: Return a generic response such as "Invalid username or password" for failed authentication attempts. Implement rate limiting and appropriate account lockout/progressive delays.
3. Disable Directory Indexing: Reconfigure the web server to disable directory browsing, especially for directories containing archived, operational, or backup files.
4. Remove Sensitive Backups from Web Root: Immediately remove "mediroza_db_backup_2019.sql" from the public-facing "/old/" directory. Store backups outside the web root in secured, access-controlled storage.
5. Implement Metadata Scrubbing: Remove author information and developer comments from PDFs before distribution through the patient portal and incorporate metadata scrubbing into the document-generation workflow.